Università degli Studi di Padova

DIPARTIMENTO DI INGEGNERIA DELL'INFORMAZIONE



Digital Forensics & Biometrics

A.A. 2026/2027

NETWORK FORENSICS

Simone Milani
Room 216
DEI A

Phone: 049 827 7641
E-mail:
simone.milani@dei.unipd.it

NETWORK FORENSICS

INTRODUCTION TO NETWORK FORENSICS

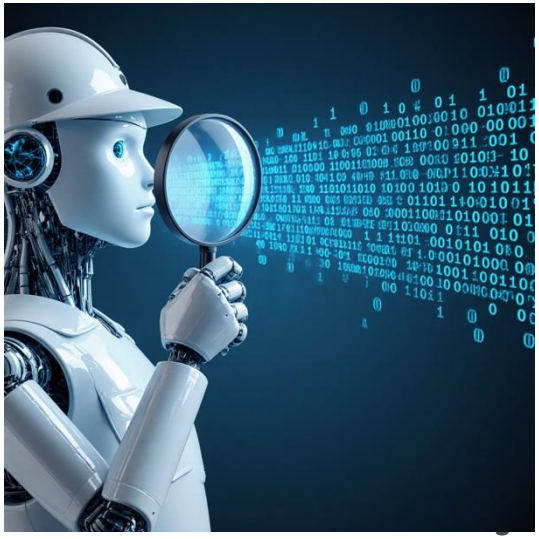
Network forensics: monitoring and analyzing computer network traffic to *gather information*, *compile evidence*, and/or *detect intrusions*.

- Volatile
- Rarely-logged

Uses:

Security
- Monitoring for intrusions
- Network evidence may be the only type if a drive was wiped clean

Law enforcement
- Reassembling transferred files
- Finding keywords
- Searching for keywords
- Parsing messages
- Examining packet filters
- Examining firewalls
- Examining existing systems



NETWORK FORENSICS OPERATIONS

Multi-sensors data fusion

collect the logs from all network security products, deployed in the entire network and perform data fusion.

- packet analyzers (wireshark / tcpdump)
- intrusion detection systems (snort),
- routers, firewalls, log servers, etc.
- alerts generated by IDS,
- statistics from protocol analyzers and attack information by observing various threshold values

Dempster-Shafer theory for information fusion determines the validity of the attack.

Identification of Attack Events

Large amount of memory and storage is usually required; network events useful for investigative requirements need to be identified and an effective mechanism is to be in place to identify attack features from the traces.

Attack Reconstruction

Important events involving intruders' interaction with the compromised system are reconstructed and the methodology of the attackers is analyzed.

Traceback and Attribution

determining the origin of a packet.

Techniques based on packet marking, packet logging or hybrid approaches.

Attribution relies on analyzing the data packets transmitted, applications being run, traffic patterns observed and protocols violated.

Incident Response

are to be launched immediately when the alerts begin; attacker must not be aware of the response.

Detection and validating the incident by reviewing pertinent logs, network topology, etc.

It determines the vulnerability exploited in the compromise of a system and enforces protection against exploitation of the same on other systems. It develops a strategy regarding containment, eradication, recovery, and investigation.

NETWORK FORENSICS' STEPS

Identification: recognizing and determining an incident based on network indicators.

Preservation: securing and isolating the state of physical and logical evidences from being altered, such as, for example, protection from electromagnetic damage or interference.

Collection: Recording the physical scene and duplicating digital evidence using standardized methods and procedures.

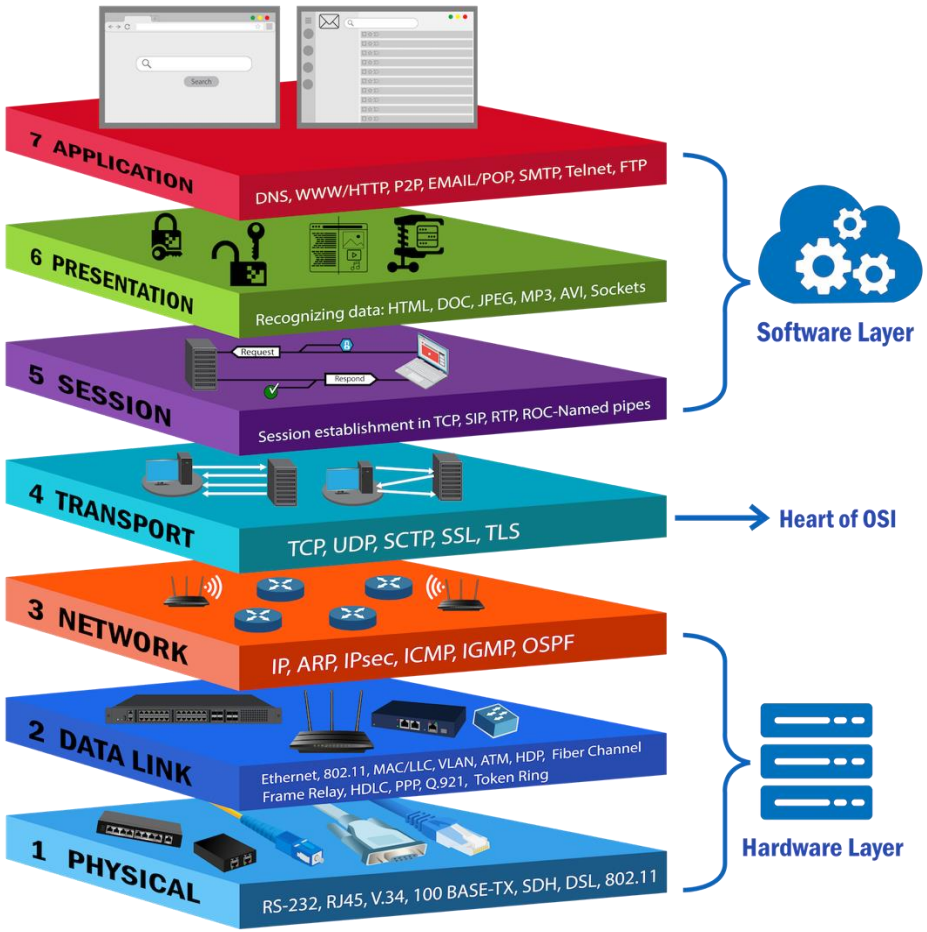
Examination: in-depth systematic search of evidence relating to the network attack. This focuses on identifying and discovering potential evidence and building detailed documentation for analysis.

Analysis: determine significance, reconstruct packets of network traffic data and draw conclusions based on evidence found.

Presentation: summarize and provide explanation of drawn conclusions.

Incident Response: The response to attack or intrusion detected is initiated based on the information gathered to validate and assess the incident.

OSI STACK STRUCTURE



Images, voice, test

Formats

Packet streams

Path

Frames

Physical signals

OPERATING LAYERS IN NETWORK FORENSICS

- **Ethernet analysis**
  - Process packets on the same network segment
  - permits profiling activities and analyzing local behaviours (alarms)
- **TCP/IP – Router analysis**
  - Mainly involves data tracking
  - Follow compromised packets, reverse route, ID the source
  - Network layer also provides authentication log evidence
- **Internet/Server based analysis**
  - Includes web-browsing, email, chat, and other types of traffic & communication
  - Server logs collect information
  - Email accounts have useful information except when email headers are faked
  - User account information associated with a particular user
- **Wireless analysis**
  - A sub-discipline of the field
  - To get that which is considered "valid digital evidence"
  - This can be normal data OR voice communications via VoIP
  - Analysis is similar to wired network situations, with different security issues

DATA COLLECTION METHODS



"Catch-it-as-you-can"

- All packets/data are captured
- Large storage needed
- Analysis in batch mode
- Usually @ packet level
- For later analysis



"Stop, look, and listen"

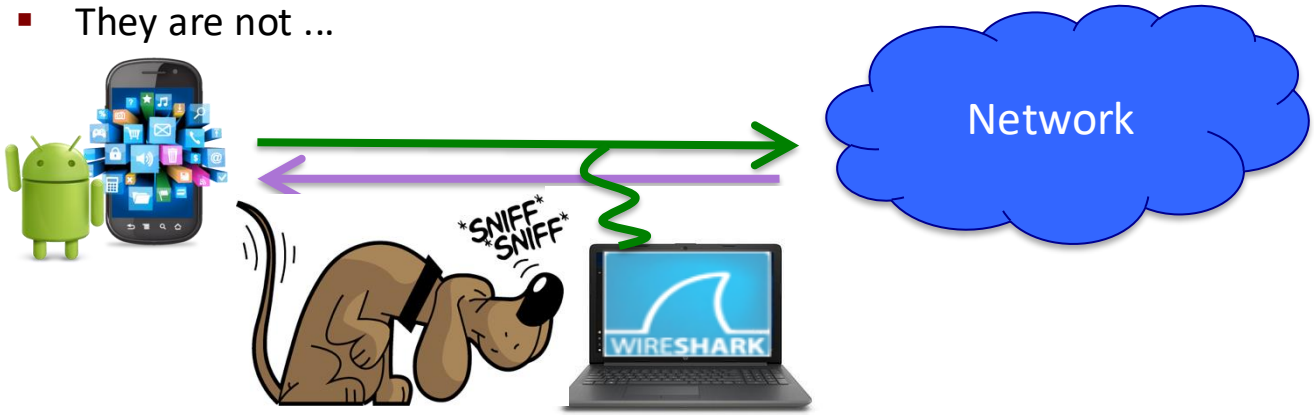
- Requires faster processor for incoming traffic
- Each analyzed in memory
- Certain ones are stored
- Usually @ packet level
- Real-time filtering

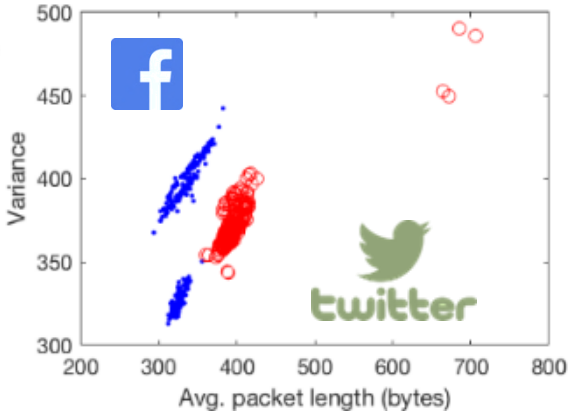
See packet sniffers or analyzers

"sniffer captures each packet and, if needed, decodes the packet's raw data, showing the values of various fields in the packet, and analyzes its content according to the appropriate RFC or other specifications"

EXAMPLE: TRAFFIC ANALYSIS ON ENCRYPTED CHANNELS

- Packets can be sniffed or eavesdropped from cabled or wireless networks
- We assume that encryption keeps our communications and data safe …
- They are not …





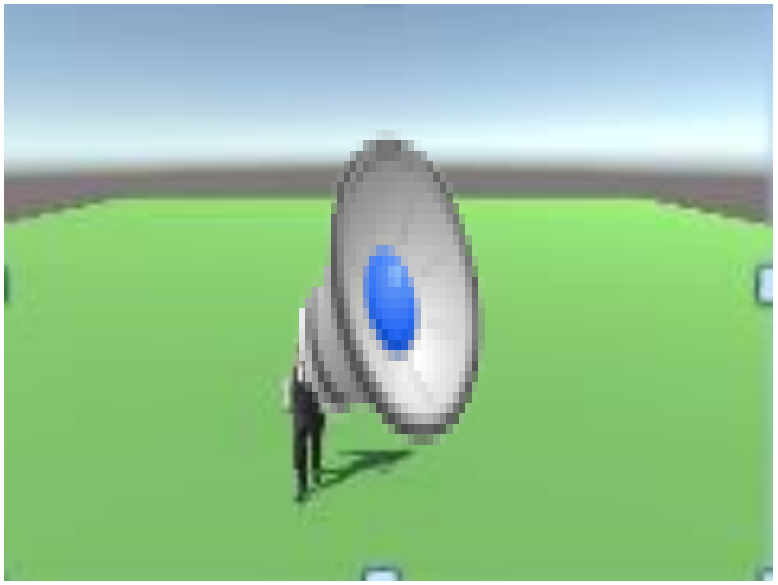
User activities can be profiled from packet lengths [Conti et al., 2016]

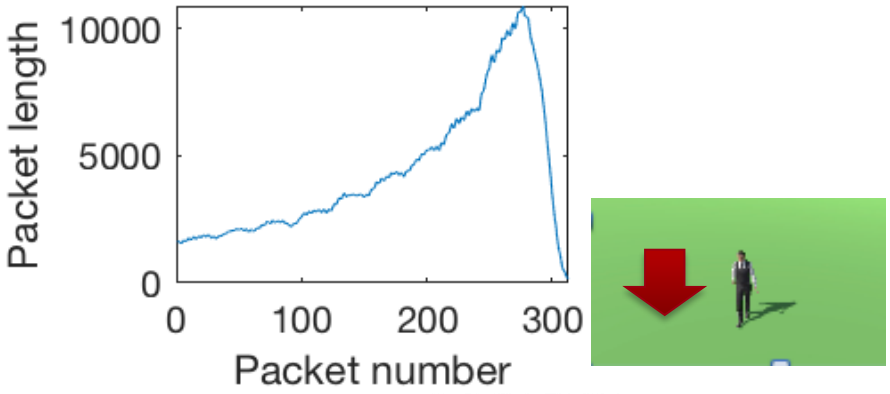
What about video surveillance?

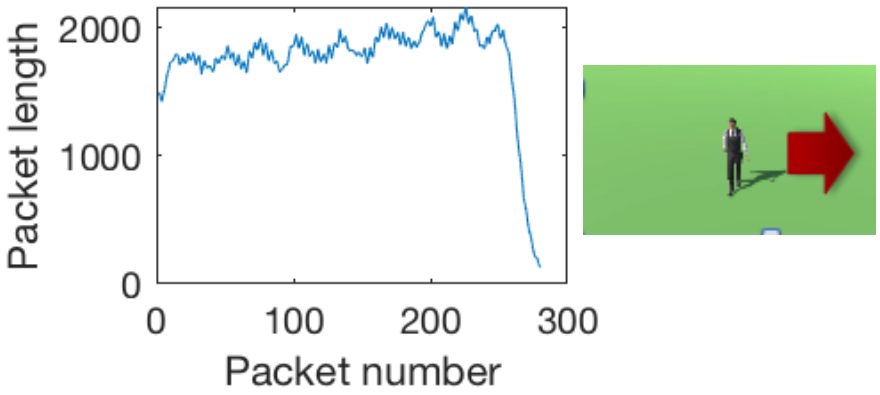


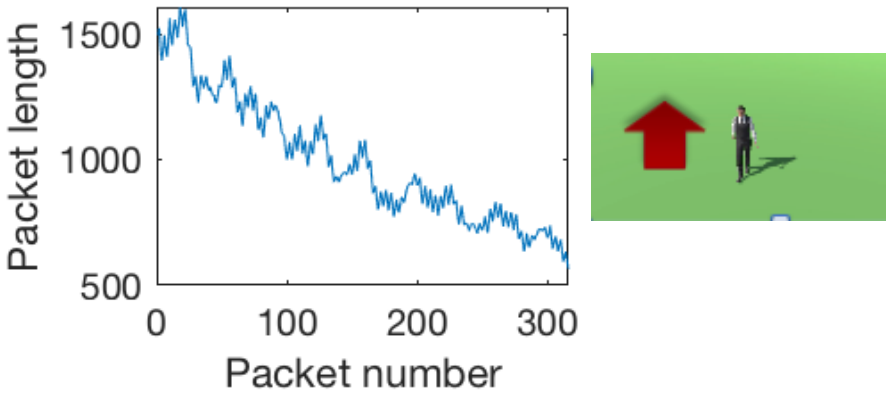
Looking through walls [Mari et al., 2021]

VIDEO SURVEILLANCE STREAMING

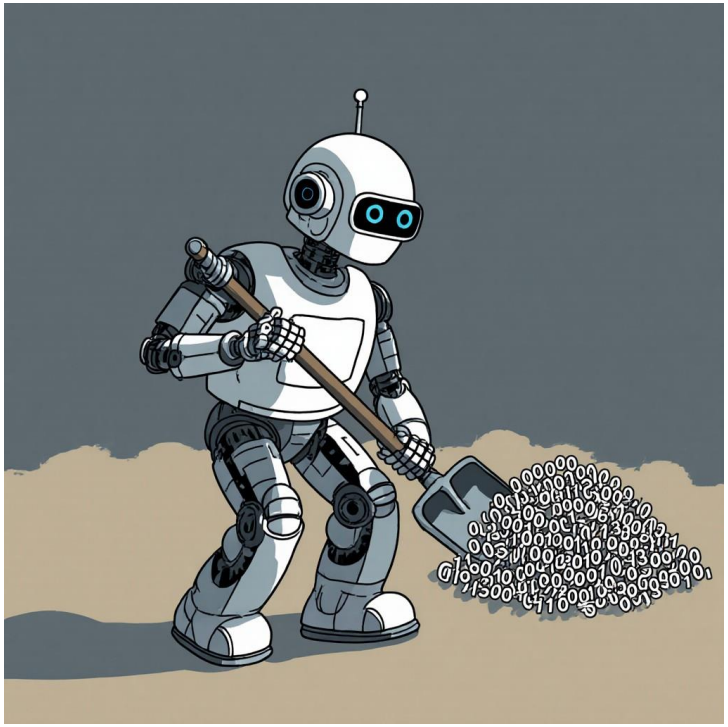








COLLECTING EVIDENCES



ETHERNET ANALYSIS

ETHERNET

Technology used in used in local area networks (LAN), metropolitan area networks (MAN) and wide area networks (WAN)

- High bit rates *2.94 Mbit/s ('76) to 400 Gbit/s (today)*
- Data-link layer
- Data stream partitioned into frames
  - Source
  - Destination
  - Error checking code

} 48-bit MAC address

Ethernet_II Frame

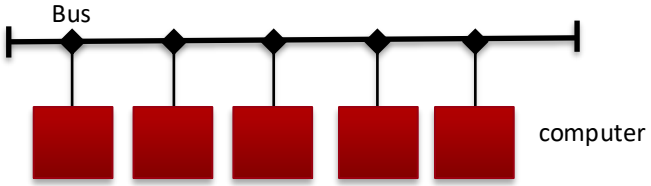
Preamble 8 bytes	DA 6 bytes	SA 6 bytes	Type 2 bytes	Data	FCS 4 bytes

EtherType	Protocol
0x0800	IPv4
0x0806	ARP
0x86DD	IPv6

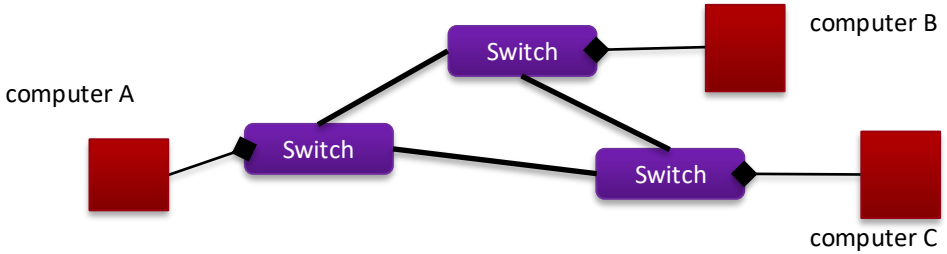
802.3_Ethernet Frame

Preamble 8 bytes	DA 6 bytes	SA 6 bytes	Length 2 bytes	Data	FCS 4 bytes

Shared Media: any information is received by all; interrupts happen only when applicable packets are received: the card ignores information not addressed to it.



Original Ethernet:
- Collision
- Low throughput



Modern Ethernet:
- Station -> switch -> destination (lower collision probability)
- 10-Base T : full duplex mode (collision free)

Employed devices:
- repeater and hubs *(cope with signal degradation and timing reasons; forwards to all)*
- bridges and switches (selective forwarding; frail to single points of failure, dumping attacks that trick switches into sending data to a sniffing machine, scalability and security issues e.g. switching loops, broadcast radiation and multicast traffic, bandwidth choke points)

How a sniffer work

Every PC on a LAN has two addresses: MAC (used by card) and IP (used by protocols)

ARP: Address Resolution Protocol (RFC 826) maps IP address into MAC addresses

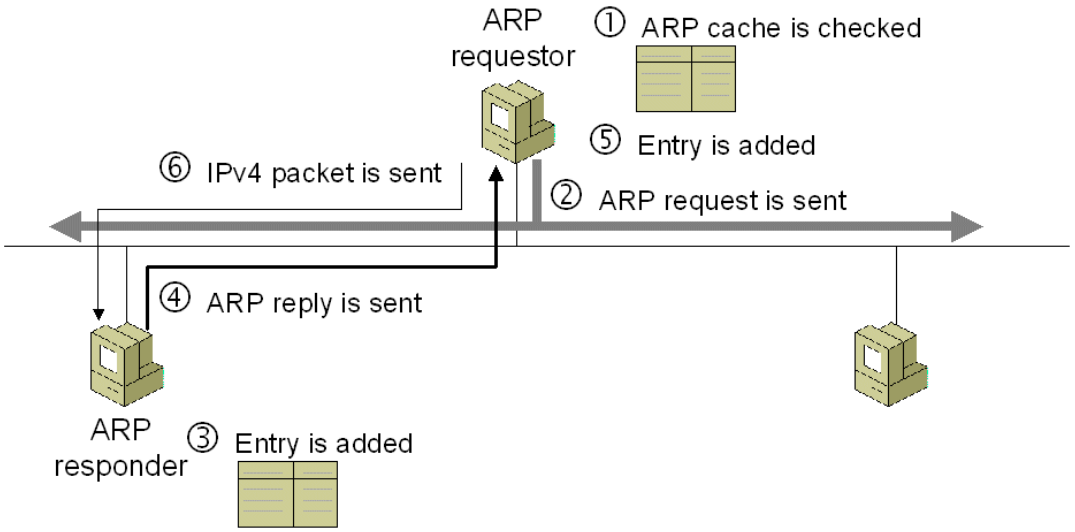
ARP cache stores all the pairings IP/MAC addresses.

Sniffer on shared Ethernet (passive)

A machine running a sniffer accepts all the frames regardless of the MAC address (promiscuous mode)

Sniffer on switched Ethernet (active)

Previous strategy does not work.



ARP spoofing: sends an ARP reply even if it was not asked for. It replace the correct MAC address with its own. All the traffic passes Through the eavesdropper.

Linux command: arpspoof

MAC flooding: switches keep a table mapping MAC addresses to physical ports: limited memory for this. Flod the switch with false MACs until the switch can not keep up: *failopen mode*. The switch then operates like a hub broadcasting all the packets to all the machines.
n.b. This method degenerates network services – must be used for a limited amount of time!

Linux command: macof

EAVESDROPPING PACKET STREAM

- Uses monitoring tools or sniffers (traditional Eth: sniffing machine; modern Eth: switch with monitoring port)
- *Wireshark*(a.k.a. Ethereal)
- Then protocols can be consulted, such as the Address Resolution Protocol (ARP)
- Network Interface Card (NIC), but can be averted with encryption



Uses of sniffers:

Analyze network problems
Detect network intrusion attempts
Detect network misuse by internal and external users
Documenting regulatory compliance through logging all perimeter and endpoint traffic
Gain information for effecting a network intrusion
Isolate exploited systems
Monitor WAN bandwidth utilization
Monitor network usage (including internal and external users and systems)
Monitor data-in-motion
Monitor WAN and endpoint security status
Gather and report network statistics
Filter suspect content from network traffic
Serve as primary data source for day-to-day network monitoring and management
Spy on other network users and collect sensitive information such as login details or users cookies (depending on any content encryption methods that may be in use)
Reverse engineer proprietary protocols used over the network
Debug client/server communications
Debug network protocol implementations
Verify adds, moves and changes
Verify internal control system effectiveness (firewalls, access control, Web filter, spam filter, proxy)

How a sniffer work

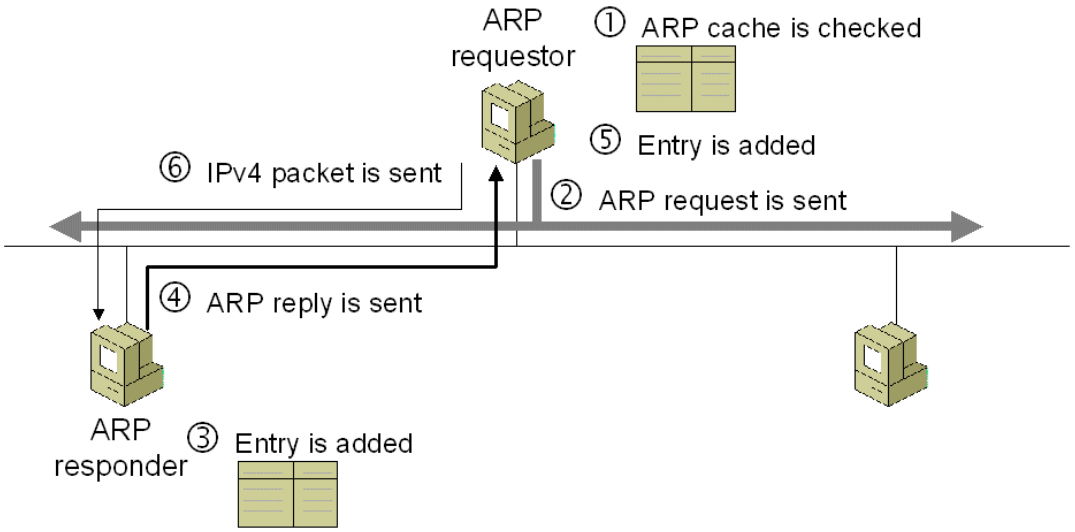
Every PC on a LAN has two addresses: MAC (used by card) and IP (used by protocols)

ARP: Address Resolution Protocol (RFC 826) maps IP address into MAC addresses

ARP cache stores all the pairings IP/MAC addresses.

Sniffer on shared Ethernet (passive)

A machine running a sniffer accepts all the frames regardless of the MAC address (promiscuous mode)



Sniffer on switched Ethernet (active)

Previous strategy does not work.

ARP spoofing: sends an ARP reply even if it was not asked for. It replace the correct MAC address with its own. All the traffic passes Through the eavesdropper.

Linux command: arpspoof

MAC flooding: switches keep a table mapping MAC addresses to physical ports: limited memory for this. Flod the switch with false MACs until the switch can not keep up: *failopen mode*. The switch then operates like a hub broadcasting all the packets to all the machines.
n.b. This method degenerates network services – must be used for a limited amount of time!

Linux command: macof

HOW TO DETECT A SNIFFER

Ping method

Send a packet with the IP address of the suspect machine without or with a wrong MAC address. All machines should reject it since MAC does not match. Only the sniffer answers (it does not bother accepting packets with a different MAC address)

ARP method

Exploits ARP cache. Sends a non-broadcast ARP, which is cached by a machine in promiscuous mode. Then, send broadcast IP packet with correct IP but different MAC address. Only machine with correct MAC address from the sniffed ARP frame will respond.

Local host analysis

Hackers may have compromised your terminal and left sniffers. Use `ifconfig` and analyze the answer

Latency method

Most sniffers do some parsing. Huge amount of data is sent through the network, and during the transmission, the suspect machine can be pinged. In promiscuous mode, it parses all packets and therefore, ping response is delayed. False positives are possible (traffic can be delayed by the network load).

ARP watch

gateway can be spoofed. `arpwatch` can be used to check the ARP cache of a terminal: look for duplicates. With DHCP there can be many false alarms: increase the lDHCP lease time.

IDS

Snort record IP/MAC pairings of packets. Whenever a mismatch is found, it generates an alert

SNIFFING SOFTWARES

Tcpdump
works on Linux systems, old software (sniffers' granddaddy), permits real-time filtering)
www.tcpdump.org/daily/tcpdump-current.tar.gz

Wireshark
sniffs at both frame and packet level, allows filtering
https://www.wireshark.org/

Snort
sniffs and do packet logging as well, can be used for IDS
https://www.snort.org/

Ethereal
Similar to previous ones, live captures
https://www.snort.org/

Hunt
Exploits weakness in TCP/IP protocol; allows hijacking active connections and take over their control

Ettercap
Designed for switched LAN; allows performing MITM attach against SSH and SSL; performs password collecting for several protocols
http://www.ettercap-project.org/

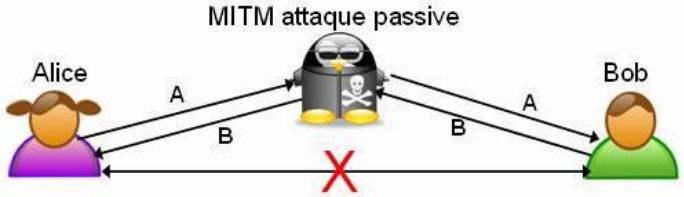
Dsniff
Comprehensive sniffer package
https://www.monkey.org/~dugsong/dsniff/

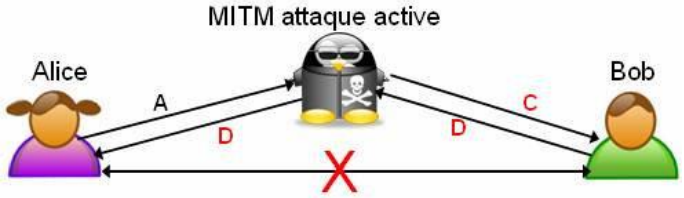
ANTI-SNIFFING MEASURES

- Tools that protect the ARP against Man-in-the-Middle (MITM) attacks

e.g. ARP Spoofing, ARP Cache Poisoning, ARP Poison Routing

an attacker sends (spoofed) ARP on LAN. The aim is to associate the attacker's MAC address with the IP address of another host, such as the default gateway.





- Cryptography (SSH, SSL, https, PGP or GnuPG for emails

- Sniffing detection tools
  - **Snort** enables IDS
  - **Anti Sniff** detects if a computer is in promiscuous mode (http://www.securitysoftwaretech.com/overview/)
  - **ARP watch** keep track of MAC/IP address pairings
  - **Neped** (outdated)

- Stronger security measures on network protocols
  - implemented on switches, gateway, etc. they perform a set of checks in real-time, like whether a MAC address I is associated to 2 IP addresses, and so on
  - add MAC address permanently for authorized machine in your networks
  -

PCAP FILES

PCAP files

Stores information about sniffed streams (tools: libpcap)



Global header

guint32 magic_number; → 0xa1b2c3d4, 0xd4c3b2a1 — Defines format and ordering

guint16 version_major;

guint16 version_minor;

gint32 thiszone; → *Correction (in sec) between time zone and GMT (UTC)*

guint32 sigfigs; → *Accuracy of time stamp*

guint32 snaplen; → "snapshot length" for the capture

guint32 network; → link-layer header type,

Packet header

guint32 ts_sec; → timestamp (in sec)

guint32 ts_usec; → timestamp (in microsec)

guint32 incl_len; → Length of stored bytes from packet

guint32 orig_len; → Length (real) of the transmitted packet

PCAP->CSV FILES

app	action	seq.	action start	flow nr.	IP dest.	IP dest. resol.	port source	port dest.	flow length	flow start	packets length total
facebook	open facebook	1	1383129102.11	0	x		14146	53	2	XXXX	[79, -185]
facebook	open facebook	1	1383129102.11	1	x		18748	53	2	XXXX	[78, -203]
facebook	open facebook	1	1383129102.11	2	y	a	47559	443	29	XXXX	[250, -1514,...]
facebook	open facebook	1	1383129102.11	3	y	b	42963	443	30	XXXX	[250, -1514,...]
facebook	open facebook	1	1383129102.11	4	x		7633	53	2	XXXX	[76, -183]
facebook	open facebook	1	1383129102.11	5	y	a	33554	443	9	XXXX	[250, -1514,...]
facebook	open facebook	1	1383129102.11	6	y	a	47559	443	2	XXXX	[764, -1014]
facebook	open facebook	1	1383129102.11	7	y	a	42599	443	31	XXXX	[282, -1514, ...]
facebook	open facebook	1	1383129102.11	8	y	b	42963	443	5	XXXX	[92, 92, 93, ...]
facebook	open facebook	1	1383129102.11	9	y	c	49785	443	46	XXXX	[250, -1514, ...]
facebook	open facebook	1	1383129102.11	10	x		39051	53	2	XXXX	[78, -206]
facebook	open facebook	1	1383129102.11	11	y	b	42963	443	7	XXXX	[92, 92, 93,...]
facebook	menu selection	1	1383129213.08	12	y	b	42963	443	7	XXXX	[92, 92, 93, ...]
facebook	menu selection	1	1383129213.08	13	y	b	42963	443	10	XXXX	[92, 92, 93, ...]
facebook	menu selection	1	1383129213.08	14	y	a	33554	443	2	XXXX	[-93, 93]
facebook	menu selection	1	1383129213.08	15	y	a	42599	443	9	XXXX	[917, 1514, ...]
facebook	replacing menu in initial position	1	1383129244.01	16	y	a	47559	443	1	XXXX	[-93]
facebook	replacing menu in initial position	1	1383129244.01	17	y	c	49785	443	1	XXXX	[-93]
facebook	replacing menu in initial position	1	1383129244.01	18	y	b	42963	443	7	XXXX	[92, 92, 93, ...]
facebook	edit search selection	1	1383129275.01	19	y	b	42963	443	7	XXXX	[92, 92, 93,...]

Session of packets

NB: > 0 outgoing
<0 incoming

TROJAN HORSE EAVESDROPPING

SMS Trojan, backdoor trojan,



- Sniffer exploits vulnerability of network streams
- It is possible to take control of devices
- Use of Trojan Spyware
- Collect communications, logs, voice call, images/videos (i.e., computer and sensed activity).
- Different from MITM (attacker is a relay)

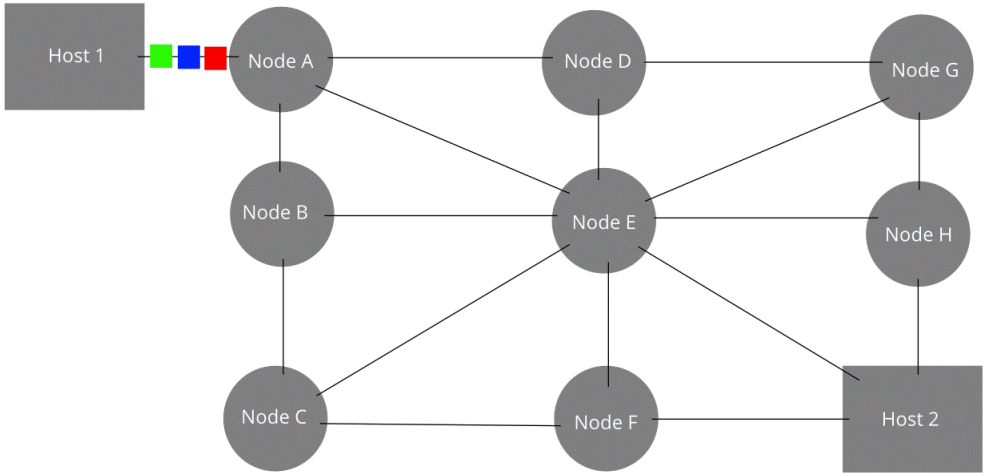
How get control? Click on link, SMS, phone call, install malicious app

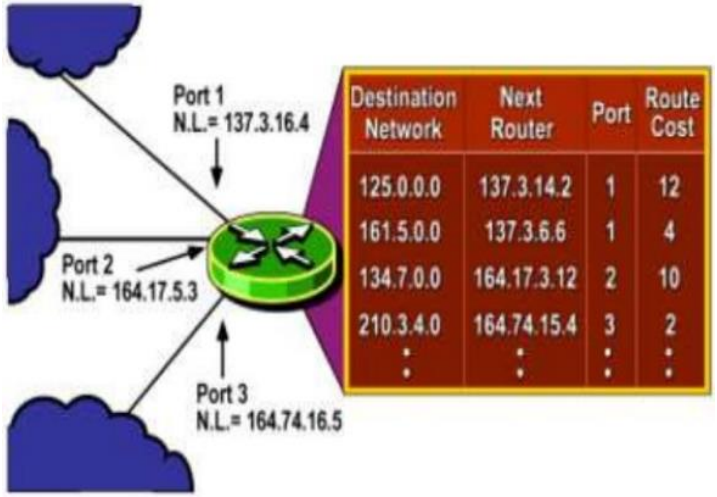
ROUTING ANALYSIS

TCP/IP ROUTER

- Device specialized on sending packets across data networks
- responsible for Interconnecting networks by selecting the best path for a packet to its destination
- Forward packets from one network/segment to another one (according to a routing table)
- Different routes are possible
- Information is stored on routing tables

The original message is Green, Blue, Red.

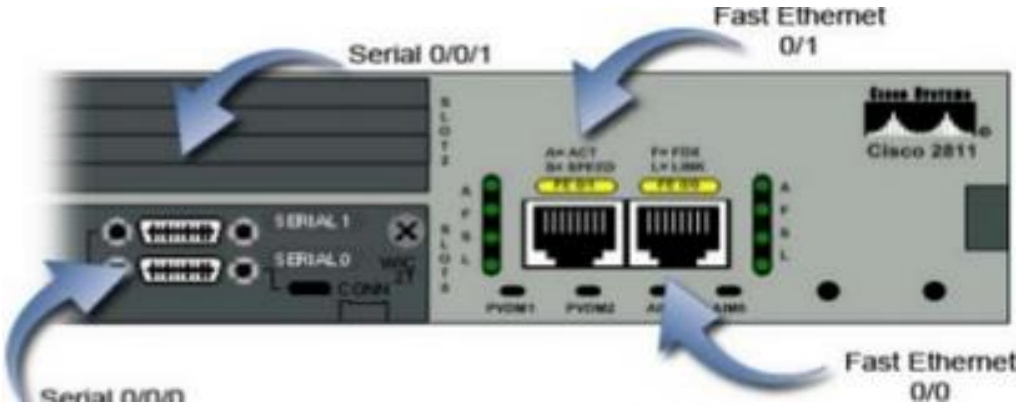




ROUTING ON TCP/IP

Communicating with routers:

- Local cable
- Modem
- Terminal emulation software



Components:

- ROM
- POST
- IOS
- RAM
- Flash memory
- NVRAM

Ports:

- LAN Ports
- WAN Ports
- Administrative ports
  - -console ports
  - -auxiliary ports

Working modes:

- Setup mode
- User mode
- Priviledged mode
- Global configuration mode
- Interface mode

ROUTER ATTACKS

Importance of preserving routers from attacks

- Heart of networks
- Few procedures for hardening security
- Slower in getting upgraded
- Few people monitor their configuration regularly
- Few security measures
- There are billions of them

Attacks

- Reconnaissance
- Scanning and enumeration
- Gaining access
- Escalation of privilege
- Maintaining access
- Covering tracks and placing backdoors
- DoS attacks
- Packet mistreating attacks
- Routing table poisoning
- Persistent attacks

MOST COMMON ROUTER ATTACKS

- **Denials of Service (DOS)**

  used by hackers to disrupt an entire network and router.
  series of requests; flood the routers networks with message requests, e.g., Internet Control Message Protocol (ICMP) packets; sent over a short time from multiple locations.

- **Packet mistreating**

  injects packets with malicious codes designed to confuse and disrupt the router and network.
  as the routers become more and more confused, malicious data starts to circulate around the network creating a loop = congestion

- **Routing table poisoning**

  these aggressive attacks are achieved by editing the information packets that are cycled through the routing table.

- **Hit and run attacks**

  one off attack on a specific network or router: malicious data is injected into router through code. If attacker fails at their first attempt, they may or may not progress and make further attempts on the system.

- **Persistent attacks**

  occur and continue to occur until the attacker has achieved their goal.

GATHERING VOLATILE ROUTER DATA

- connect to console port; cable + laptop with terminal emulation software
- record System Time and determine who is logged on
- save router configuration
- review routing tables and detect malicious static routes modified by attacker
- view ARP cache looking for evidence of IP and MAC spoofing

Order of volatility

1. Registers and cache.
2. Routing tables.
3. Address Resolution Protocol cache.
4. Process table.
5. Kernel statistics and modules.
6. Main memory.
7. Temporary file systems.
8. Secondary memory.
9. Router configuration.
10. Network topology.

CAUTIONS AND DOCUMENTING

DOs

- Access router through the console
- Record all your console session
- Run show commands
- Record actual time and router time
- Record volatile information

DON'Ts

- Reboot the router
- Access the router through the network
- Run configuration commands
- Rely only on persistent information

Documentation

- *Chain of custody*:
  prove the integrity of evidences
- *Case reports*:
  employee remediation, employee termination, civil proceedings, criminal prosecution, case summary, bookmarks
- *Incident response*:
  effort to define and document the nature and the scope of a computer security incident

BAD GUYS AND GOOD GUYS

- Internet Router Protocol Attack (IRPA) suite
  a suite of tools designed to abuse inherent design insecurity.
  tools: ass, igrp, hsrp
- VIPPR
  can be used for MITM attacks for compromised routers
- UltimaRatio
  tools that exploit vulnerabilities on routers
- Research



- Router Audit Tool (RAT)
  Scores overall security on router
- Manuals, books, reviews, papers
  on securing routers
- Strong authentication
  Encrypted traffic mgmt, two-phase authentication, centralized authentication source



SERVER LOGS

SERVER LOG

- automatically generated and maintained by a server, it records all activities and events that occurred.
- detailed record, like a diary, of everything the server does, including access attempts, data requests, and any errors encountered



Server logs are useful for:

Troubleshooting:
pinpoint the cause of errors and identify unusual behavior on the server.

Security:
reveal suspicious activity, like multiple failed login attempts or unusual access patterns

Performance monitoring:
insights into website traffic, resource usage, and potential bottlenecks.

Compliance:
auditing purposes to ensure compliance with regulations and data protection laws.

SERVER LOG

Formats include plain text, structured, binary, syslog, CLF, and ELF.

Log Type	Description	Common Contents
System Logs	OS events, processes, and errors	• Kernel logs • Authentication Logs • Security Logs
Application Logs	Capturing events and errors by applications	• Contextual Information • Timestamps • Log Levels
Security Logs*	Logs tracking security events and alerts	• Authentication logs • Access logs • Intrusion detection
Audit Logs	Logs used for compliance	• User actions • Data access events • System changes
Event Logs	Logs tracking significant system, security, and application events	• System events • Application-specific events

* Generated by Antivirus program, firewall, intrusion detection/prevention system, vulnerability management, authentication server, router

LOG ANALYSIS STRATEGIES (1/2)

Server or terminals are configure in order to save information at each remote access

Number of visits and number of unique visitors (no repetitions)
Visit duration and last visits
Authenticated users, and last authenticated visits
Days of week and rush hours
Domains/countries of host's visitors.
Hosts list
Number of page views
Most viewed, entry, and exit pages
File types
OS used
Browsers used
Robots used
HTTP referrer
Search engines, key phrases and keywords used to find the analyzed web site
HTTP errors
Some of the log analyzers also report on who is on the site, conversion tracking, visit time and page navigation.

NCSA Common log format [host; ident; authuser; date; request; status; bytes]

Example: 127.0.0.1 user-identifier tomasin [30/Aug/2017:10:25:16 -0700] "GET /apache_pb.gif HTTP/1.0" 200 1068

A "**–**" in a field indicates missing data.
0.0.1 IP address of the client (remote host) which made the request to the server.
User-identifier is the RFC 1413 identity of the client.
tomasin is the user id of the person requesting the document.
[**30/Aug/2017:10:25:16 -0700**] is the date, time, and time zone that the request was received
"**GET /apache_pb.gif HTTP/1.0**" is the request line from the client.
200 is the HTTP status code returned to the client. 2xx is a successful response, 3xx a redirection, 4xx a client error, and 5xx a server error.
2326is the size of the object returned to the client, measured in bytes

Logs play an important role in tracking each client computer's activity

- keep an eye on your network for vulnerabilities
- identify who introduces risks, and help that person to use better precautions.

LOG ANALYSIS STRATEGIES (2/2)

Extended log format (ELF) [host; ident; authuser; date; request; status; bytes]

Logs play an important role in tracking each client computer's activity

- keep an eye on your network for vulnerabilities
- identify who introduces risks, and help that person to use better precautions.

Same approach can be applied to any log file (application, machines, …)

WIRELESS CHANNEL SENSING

methodology and tools required to collect and analyze (wireless) network traffic that can be presented as valid digital evidence.

- Plain data
- Multimedia contents (video, audio from VoIP services)

Operations:

- Sense the wireless channels -multiple freq. (many Aps or roaming)
- Consider frames types, sizes, approximate number of frames and bandwidth requirements, motion conditions
- must be able to accommodate the theoretical maximum throughput associated to all the channels (storage, processing power)

Wireless traffic acquisition in a moving scenario (car prosecution)	
Wireless technology	802.11b/g (all 14 channels)
Capture time	25 minutes
Amount of data collected	74 Mbytes (~265,000 frames)
Wireless networks detected	60
Wireless networks taxonomy	12 Open (20%), 42 WEP (70%), 6 WPA (10%)
Wireless networks with data traffic	13
Wireless traffic taxonomy	25% Data, 39% Management, 36% Control



Wireless traffic acquisition in a static scenario (parking lot)	
Wireless technology	802.11b/g (all 14 channels)
Capture time	5 minutes
Amount of data collected	24 Mbytes (~107,000 frames)
Wireless networks detected	60
Wireless networks taxonomy	4 Open (17%), 17 WEP (71%), 3 WPA (12%)
Wireless networks with data traffic	6
Wireless traffic taxonomy	6% Data, 53% Management, 41% Control



FEATURES FOR GOOD WF TOOLS

- 15 radio components (or cards); support channel hop
- use of a GPS (Geographical Positioning System) to get accurate timestamps and outdoor locations (log files)
- capture all traffic without applying any capture filter - filters could be used to collect traffic from specific AP or clients based on their MAC addresses (BSSID or station address).
- completely passive device (hardware attenuator to reduce power: monitor mode for wireless card)
- external antenna connector (to increase the gain)
- remote access
- Side information regarding the data collection (received signal strength or RSSI, capture device, channel, and other signal/noise quality information)

Analyzing evidences: authentication, attribution, monitoring

EXAMPLE: INTRUSION DETECTION SYSTEMS (IDS)

Network Intrusion Detection System (NIDS) monitor at network layer by evaluating network traffic

Host-based Intrusion Detection System (HIDS) operate directly on the computer hosts by monitoring system logs, system processes, files, or network interface

Protocol-based Intrusion Detection System (PIDS) monitor a specific protocol (e.g. HTTP)

Application Protocol-based Intrusion Detection System (APIDS) focus on some applications (e.g. monitoring SQL protocols).

How can you do this? Firewalls, IDSs, computer workstations, anti-virus software, databases, end-user applications

Usually they do not work jointly!

HOST-BASED IDS

Monitor

- system activities,
- log files,
- incoming network traffic
- system calls
- audit logs
- error messages

} OS



NIDS detect attack, HIDS tell if they were successful

HIDS detect attacks performed locally (using USB pens, out-of-band attacks, terminals, etc.)

Out-of-band is a term used to describe any traffic or access that doesn't traverse the public or monitored network (private network, a console connection, or an RS232 serial connection).

Robust to fragmentation and TTL (Time-To-Live) manipulation: *stealth attacks*

NIDS can be fooled by splitting packets into multiple chunks (which are reassembled at the receiving host) or manipulating the TTL.

Problems:

- Manageability
  Maintenance and configuration is time consuming and inefficient (must be done on each device)
- Micro view of network attacks
  can't detect common reconnaissance attacks against the host or a range of hosts (ping sweeps or port scans)
- Compromised hosts
  network connection of IDS can be disabled; no notification is sent to the manager
- Operating systems' limitations
  hosts may have different OS, IDS software must work on each of them.

NIDS

use probes or sensors installed throughout the network sniffing the network (*promiscuous mode*) looking for traffic that matches a defined profile or signature. Once the match is positive, the probe sends an alert and can take action to prevent any additional access.



See intrusion from a network perspective

- detect ping sweep or port scan on multiple hosts
- do not depend on the resources of host machines (no waste of network and CPU capabilities; no OS compatibility issues)

Two interfaces: Monitor Interface (MI) and Command & Control Interface (CCI)

Separate management network

Problems:

- Bandwidth

  Network probes must receive all network traffic, reassemble that traffic, and analyze the traffic. Network size can increase as well: the NIDS system must scale.

- Packet fragmentation and reassembly

  Hackers conceal their activity from NIDS fragmenting their packets: the packet needs to be reassembled (first to last or last to first) to be analyzed. No problem if no overlapping occurs: hackers send overlapped packets.

- TTL manipulation
- Encryption

NIDS (2/2)

Problems:

- Bandwidth

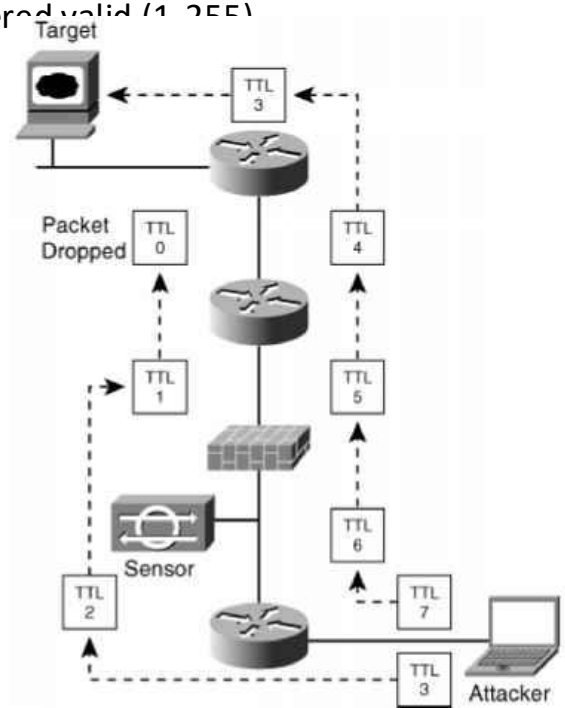
  Network probes must receive all network traffic, reassemble that traffic, and analyze the traffic. Network size can increase as well: the NIDS system must scale.

- Packet fragmentation and reassembly

  Hackers conceal their activity from NIDS fragmenting their packets (depends on MTU): the packet needs to be reassembled (first to last or last to first) to be analyzed. No problem if no overlapping occurs: hackers send overlapped packets.

- TTL manipulation
  - TTL field of TCP/IP packets specifies how long a packet should be considered valid (1-255)
  - Each time a packet passes through a router, TTL ←TTL -1
  - TTL = 0, the packet is discarded.
  - Attacker sends packet with low TTL to create fake traffic hiding attacking packets (high TTL)

  N.B. this attack requires a detailed view of the network.



- Encryption

  Data can not be seen if encrypted: place sensors outside encrypted channel.

HYBRID IDS

combine the benefits of each type of IDS.

Both the sensors and the hosts report to a centralized management or director platform

Need to manage a lot of information

They can incorporate different triggering mechanism.

IDS TRIGGER

IDS are merely packet sniffers: need to teach the IDS what is an attack.



Anomaly Detection (Profile based)

analyzes computer activity and network traffic looking for anomalies.

Anomaly: deviation from what is defined normal (by system administrator) -> *user group profile*
e.g. you won't expect telnet towards a SMTP server

How to build a user group profile
statistical sampling, rule-based, and neural networks.

Pros:

- Intruders do not know if they generate alarms (attack can not be configured on signatures)
- Detect internal attacks
- Profiles are dynamic

Cons:

- High initial prep time
- No protection during training
- Constant update as users' habits change
- Defining normal behavior can be difficult
- False positives, false negatives
- Hard to understand

Misuse Detection (Signature based)

Use signature files to detect intrusive activity (analogous to signature files commonly used in virus-scanning)

Pros:

- Files created on known attack (if matching, the attack is sure)
- Given the files, protection is instantaneous
- Easier to understand and configure (manager knows what is going on)

Cons:

- Inability to detect new or unknown attacks
- Inability to detect variations of known attacks
- Signature database administration
- Sensors must maintain state information

TRACEBACK STRATEGIES

Network forensics deals with capture, recording, analysis and investigation of network traffic to traceback the attackers.

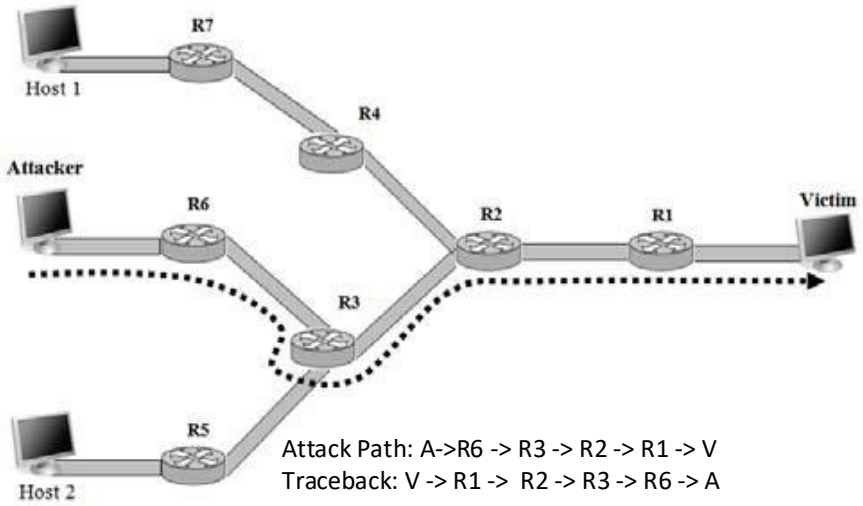
Problem: given a packet or a file, find the originating terminal.

Used in DDOS attack or againts IP spoofing

Characteristics:

Time of analysis (*real time/post mortem*)

Data source (*flow based/packet based*)



Assumptions:

- attackers are able to generate and send any packet
- multiple attackers may act coordinated
- attackers are aware of the traceback ability
- routers have limited processing and storage capabilities
- routers are rarely compromised and all routers may not participate in traceback
- suspicious packet stream are made of a few packets

Requirements:

- compatibility with existing network protocols, routers and infrastructure
- simple and minimal number of functions on transit routers
- support for incremental implementation, partial deployment and scalability
- minimal overhead of time and resources (processing, bandwidth, memory)
- fast convergence involving a few packets
- minimal involvement of the internet service provider (ISP)

TRACEBACK SOLUTIONS

Logging packets at key routers and later mining them for attack path reconstruction

source path isolation engine (SPIE): hash of multiple fields in packet
autonomous management network (AMN): monitoring manager receives requests from sensors

Packet-marking places part or the complete address of the router into the IP packet randomly with a fixed probability or only once deterministically

probabilistic packet marking (PPM)
advanced and authenticated packet marking (AAPM): 8-bit hash of address
algebraic packet marking (APM): algebraic techniques to calculate 15-bit marks as points on polynomials.
fast internet traceback (FIT): uses a fragment of the hash, the number of fragment and a distance field
deterministic packet marking (DPM)
deterministic edge router marking (DERM)

Hybrid traceback approaches integrate packet marking and packet logging to achieve the advantages of both the techniques.

distributed link list traceback (DLLT): router marks a packet, stores current IP address and packet ID in the marking table
hierarchical IP traceback system (HITS)
hybrid single packet IP traceback (HIT)
logging and deterministic packet marking (LDPM)

Autonomous System can be a group of networks regulated by one or more entity, which enforces a clearly defined routing policy.

Traceback strategies are defined here as well.

ATTACK RECONSTRUCTION

In order to refine defenses, it is necessary to analyze and understand how attackers works.

Log files are extremely important!!



Honeypot refers to a set of services, an entire operating system or even an entire network that is built to lure and contain intruders

- Designed to be compromised
- Well monitored
- No essential activity is carried on
- A way to draw attack away from more crucial elements in a network
- Useful tool to study attackers.

Problems:

From a legal point of view, honeypots can be problematic.

- honeypot has no value, and therefore, it is not possible to legally claim any damages.
- borderline between keeping attackers out of a network and inviting them.
- may be challenged as an unfair entrapment.

PRIVACY-PRESERVING NETWORKS

DEEP WEB FORENSICS

- Through Deep Web, criminal activities can be carried in anonymous way using bitcoins in transactions
- Silk Road bust – oct. 2013: $34.5M bitcoins seized by FBI, $1.5B estimated worth of 1.5M transactions.
- $300-400K/day: drug market sales
- Dark Web vs. DeepWeb: 25% sites of Deep Web involved in illegal activities
  - Drug, illegal material exchange (child pornography, terrorism propaganda, industrial data)
  - Identity Theft
  - Counterfeit money



Problems:

Internet size: 3.17B users worldwide

Anonimity: Criminal are anonymous, Bitcoins allow untraceable transactions, finding culpables can be hard

Jurisdiction: locations can be difficult to find, transnational rules make legal actions more complex

Solutions:

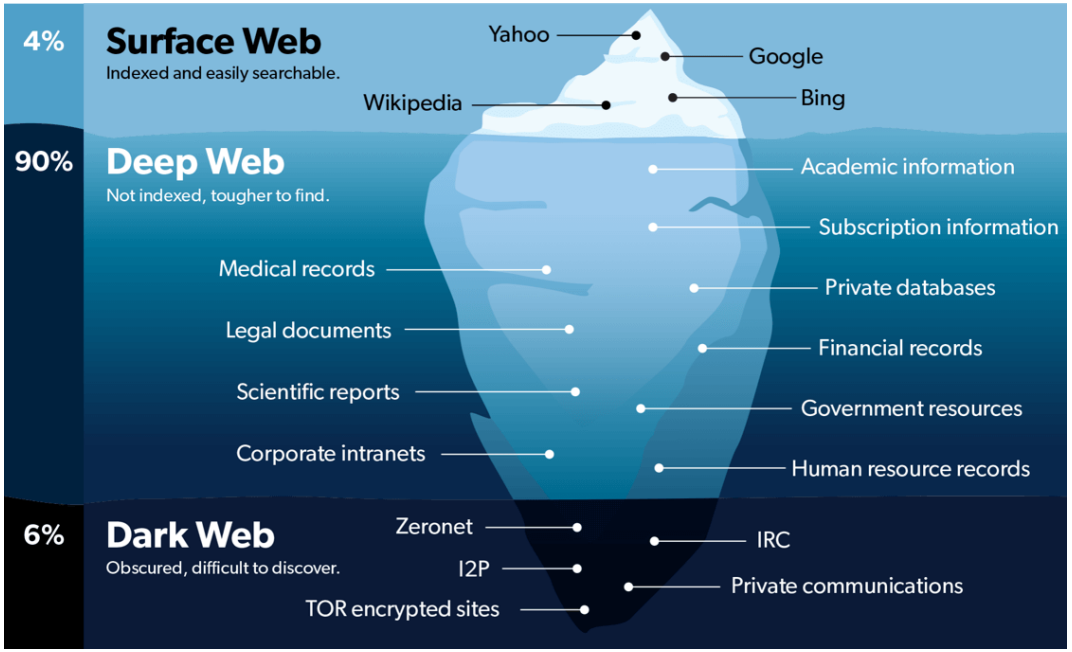
Training: several agencies (Interpol, FBI, police corpse) are investing money

Data collection methods: methods to navigate dark web, developing malware to compromise servers, hidden service/consumer data/social sites monitoring, marketplace profiling, semantic analysis

Human errors: investigators sometimes rely on the fact that usernames or contacts (and communication ways) are revealed

DEEP WEB APPLICATIONS

- Virtual Private Network (VPN) with TOR
  See next slides
- Free Anonymous Internet (FAI)
  used in blockchain because it is a decentralized deep web
- FreeNet
  Network of peers to peers and designed to securely and privately spread information on the Internet.
- ZeroNet
  torrent with Bitcoin encryption.



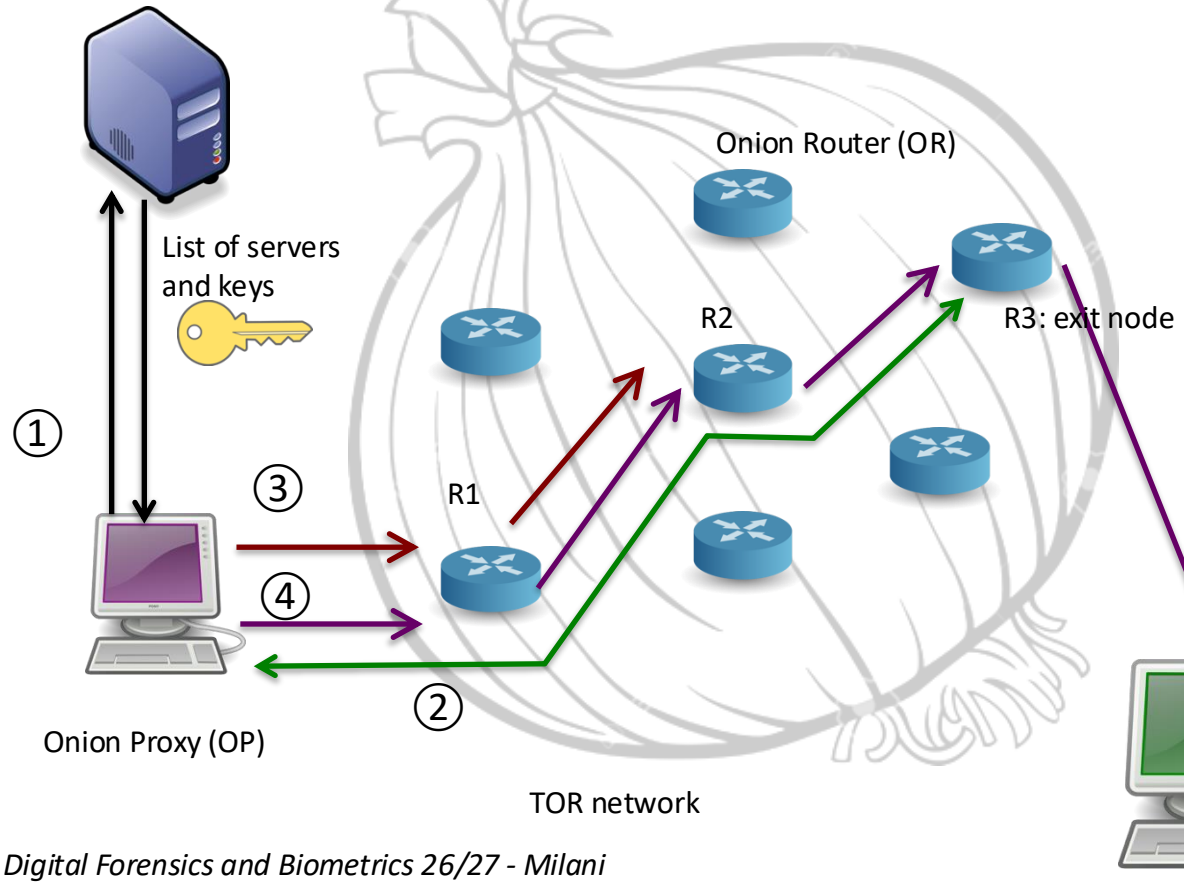
TOR NETWORK

R. Dingledine and N. Matheson, 2002
based on Onion Routing (mid '90s, Paul Syverson, M. G. Reed e D. Goldschlag)

https://www.torproject.org

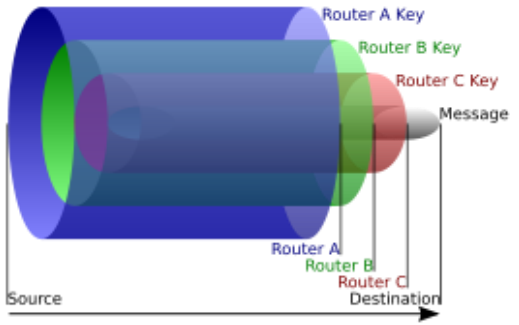
Protect privacy and anonimity.

- Data are encrypted multiple times (nested encryption)
- Every router correspond to an encryption layer
- No router knows the destination and the sending nodes.



① Ask for the list of servers
② Verify identity of servers
③ Generate session keys for the session to be initiated
④ Create a connection and transmit data

Once connection is established, data are exchanged in cells of 512 bytes (to avoid profiling)



TOR FORENSICS

Connection has been created: all messages will be sent as K1(K2(K3(DATA)))



Advantages:

- Everything is encrypted
- No-one knows both
  sending and destination nodes
- Packet lengths are disguised
- Traffic shaping is possible (sends PADDING)

Weaknesses:

- Timing analysis
- Weakness in the exit node

Strategy	solution	Aims
RAM analysis	Belkasoft RAM capturer Hex dump	types of documents, visited websites, downloaded content
Registry analysis	Regshot	TOR installation, last access, date information
Network analysis	Wireshark, miner information	Monitor network traffic
Database analysis	Locate db files	Gather connection information

OTHER SOLUTIONS

- **Spidering**
  - dark web crawler that collect information on web sites (*focused* on a specific topic, *hidden:* automatically filling hidden forms)
  - Features: URL, BoW characterizing documents,
- **Link and content analysis**
  - Measure similarity between contents
  - Methodologies: information sources, domain spidering, backlink search, filtering, indexing and analysis, clustering, activity modelling
- **Dark Network Analysis**
  - Network analysis: topology
  - Graph modelling, small-world property, scale-free property
- **Interactional coherence analysis**
  - Check communication and verify the characteristics of messages and interactions: interaction patterns
  - Lexical relations, direct address, co-reference, interaction patterns from messages
- **Authorship analysis**
  - Writing style features
  - Image/multimedia data analysis
- **Sentiment analysis**
  - Semantic classification of text/images/videos/audio
- **Affect analysis**

